

# CISM Domain 1B — Information Security Strategy: Exam Essentials

**Second half of Domain 1 (Information Security Governance, 17% of the exam).** Covers strategy development (1B1), governance frameworks and standards (1B2), and strategic planning (1B3).

## Strategy Development (1B1) — the big picture

- Information security governance is the **board's and senior management's responsibility**; governance guides strategy to ensure business alignment.
- Per ISACA, the **FIRST question** in developing a strategy: **"What is the goal of the strategy and the program it enables?"**
- Strategy development **starts with a current state assessment**: assets, vulnerabilities, threats, existing controls. You can't evaluate threats/vulnerabilities without knowing your assets. Output = gaps + baseline.
- Then define the **desired state** — a complete future snapshot: principles/policies, processes/structures, culture/ethics, information/technology, people/skills. Must include **qualitative** attributes, not just numbers.
- Key assumptions: information assets are **identified, valued, classified, and owned** — without this, business alignment is nearly impossible.
- Strategy must address risk & compliance, support business objectives, and include **measurable checkpoints** for mid-course corrections.

## Three Elements of a Strategy

- **Roadmap** — the path to the desired state: short/long-term projects and milestones, checkpoint-driven.
- **Resources** — what you have to work with: policies, standards, controls, personnel/skills, structures, audits, tools.
- **Constraints** — what limits you: internal (budget, culture, risk appetite, resistance) and external (legal/regulatory).

## Decision-Making Biases (know the names)

- **Overconfidence** — overestimating ability to predict outcomes
- **Optimism** — underestimating challenges and risks
- **Anchoring** — first numbers unduly influence later judgments
- **Status quo bias** — sticking with familiar methods even when inadequate
- **Mental accounting** — compartmentalizing funds by source, distorting decisions
- **Herding instinct** — following popular trends for social validation
- **False consensus** — assuming others share your views, overlooking risks

## COBIT — Six Governance Principles

1. **Provide stakeholder value**
2. **Holistic approach**
3. **Dynamic governance system** (adapts to change)
4. **Governance distinct from management**

5. **Tailored to enterprise needs**

6. **End-to-end governance system** (whole enterprise, not just IT)

Plus 3 framework principles: based on a **conceptual model**, **open and flexible**, **aligned to major standards**.

## BMIS — Business Model for Information Security

**4 elements:** Organization Design & Strategy, People, Process, Technology.

**6 dynamic interconnections (tensions):** Governance, Culture, Enabling & Support, Emergence (unpredictable change), Human Factors, Architecture (enables defense in depth).

## Frameworks & Standards (1B2) — quick reference

| Framework                   | What to know for the exam                                                                                                            |
|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| <b>COBIT</b>                | ISACA framework for IT governance & management; aligns IT with business goals                                                        |
| <b>BMIS</b>                 | ISACA holistic security model — 4 elements + 6 dynamic interconnections                                                              |
| <b>ISO/IEC 27001:2022</b>   | Framework for an ISMS (implement, maintain, continually improve); controls come from ISO 27002; 2022 update adds cloud security      |
| <b>NIST CSF</b>             | Cybersecurity roadmap for PRIVATE business — purely VOLUNTARY                                                                        |
| <b>NIST RMF</b>             | Security integrated into system development for FEDERAL agencies — MANDATORY where it applies                                        |
| <b>COSO ERM</b>             | Enterprise risk management; promotes a “common risk language”                                                                        |
| <b>ISO 31000 / BS 31100</b> | Risk management principles, framework, and process                                                                                   |
| <b>TOGAF, Zachman, E2AF</b> | Enterprise architecture frameworks linking business processes with security needs                                                    |
| <b>Balanced Scorecard</b>   | Strategic planning/measurement tool — 4 perspectives: Financial, Customer, Business Process, Learning & Growth                       |
| <b>CMMI</b>                 | Process maturity: 1 Initial → 2 Repeatable → 3 Defined → 4 Managed → 5 Optimizing (maintained by ISACA; Level 5 not always the goal) |

**NIST RMF = federal + mandatory; NIST CSF = private + voluntary** — a classic exam distinction. The exam tests WHEN/WHERE to apply frameworks, not memorization of their phases.

## Strategic Planning (1B3) — Workforce & Structure

- **Personnel are the first line of defense; insiders can do the most damage.** Personnel security = preventive measures against insider threats (e.g., DLP, CASB).
- Security roles belong in **job descriptions** and performance evaluations (coordinate with HR); maintain a **skills inventory**; recurring awareness training (often legally mandated).
- CISO reporting has evolved from CIO to **CFO/CEO**.

## Centralized vs. Decentralized Security

| Feature                            | Centralized | Decentralized |
|------------------------------------|-------------|---------------|
| Consistency & standardization      | Higher      | Lower         |
| Adaptability to local requirements | Lower       | Higher        |
| Resource efficiency (cost)         | Higher      | Lower         |
| Response time to local issues      | Slower      | Faster        |
| Service quality                    | Consistent  | Inconsistent  |

**Decentralized = better alignment to business unit needs** (classic exam answer), but less consistent and more expensive (no economies of scale).

## Assurance Provisions & Compliance

- **Internal audits** — dedicated departments reporting to board/senior management (larger orgs).
- **External audits** — independent third parties; may be required in regulated industries (banking, healthcare).
- **Compliance enforcement** — prioritize by risk/impact; self-reporting for low-risk areas; **leadership's commitment sets the tone** (exam tip).

## Risk Management in the Strategy

- **BIA** — consequences of losing C, I, or A, often expressed financially; feeds classification and BC planning.
- **Resource dependency analysis** — like BIA but less granular; focuses on critical systems/resources.
- **Outsourced services** — address single points of failure; ensure backup plans.
- **Threat assessment** — proactive, even without known vulnerabilities.
- **Vulnerability assessment** — beyond technical scans: physical, procedural, legal.
- **ALE** (annual loss expectancy) helps determine acceptable risk cost-effectively.
- **Insurance** for rare, high-impact events: **first-party** (own assets), **third-party** (liability, e.g., data breach), **fidelity bonds** (employee dishonesty/theft).

## Action Plan: Gap Analysis & Metrics

- **Gap analysis** — works **backward from the desired state** to the current state; repeated regularly for mid-course corrections.
- **SWOT** — Strengths/Weaknesses (internal), Opportunities/Threats (external); guides where to invest in controls.

| Metric     | Meaning                                                                                   |
|------------|-------------------------------------------------------------------------------------------|
| <b>KGI</b> | Key Goal Indicator — WHAT success looks like (e.g., achieving SOX compliance)             |
| <b>KPI</b> | Key Performance Indicator — measures PROGRESS toward KGIs                                 |
| <b>CSF</b> | Critical Success Factor — essential elements required for success; monitored through KPIs |

## CMMI Maturity Levels (low → high)

1. **Initial** — ad hoc, reactive, non-repeatable
2. **Repeatable** — consistent, predictable results
3. **Defined** — formally documented and standardized
4. **Managed** — measured and controlled via metrics/KPIs
5. **Optimizing** — continuous improvement embedded

Level 5 is **not always the goal** — cost/effort must match business objectives. Maturity can vary per control/process.

## Security Program Objectives

The program **implements the strategy**. Primary objective: protect information and related systems from harm — the **CIA Triad**: **Confidentiality** (only authorized access), **Integrity** (no improper modification), **Availability** (timely, reliable access).

## Quick Self-Check (from the handout)

1. Strategy document with specific links to business activities indicates? → **Strategic Alignment**
2. Best insight source for developing a security project plan after implementing governance? → **Balanced Scorecard**
3. Characteristic of decentralized security in a dispersed org? → **Better alignment to business unit needs**

## Last-Minute Memory Hooks

- First strategy question: what is the GOAL?
- Current state assessment first; gap analysis works backward from desired state
- RMF = federal/mandatory; CSF = private/voluntary
- KGI = destination, KPI = speedometer, CSF = what must go right
- Decentralized = local alignment; centralized = consistency and lower cost
- The program implements the strategy; its core objective is the CIA triad